Compromiso de Servidor Linux mediante Fuerza Bruta SSH y Actividades Post-Explotación

Índice

1. Resumen Ejecutivo
2. Alcance del análisis
3. Hallazgos Principales
   - 3.1 Intentos de acceso no autorizados
   - 3.2 Acceso exitoso al sistema
   - 3.3 Actividad posterior al acceso (Post-Compromise)
   - 3.4 Actividad sospechosa en servidor web
4. Impacto
   - 4.1 Impacto en la Confidencialidad
   - 4.2 Impacto en la Integridad
   - 4.3 Impacto en la Disponibilidad
5. Mapeo al Marco MITRE ATT&CK
6. Conclusión

1. Resumen Ejecutivo

Se identificó un incidente de seguridad en el servidor **app-1**, donde múltiples direcciones IP realizaron intentos de autenticación fallidos a través del servicio SSH. Posteriormente, se detectó un acceso exitoso utilizando credenciales válidas para el usuario **root**.

Tras el acceso, se evidenciaron acciones que indican modificación del sistema, incluyendo la creación de usuarios, cambios en reglas de firewall y posibles configuraciones inseguras en servicios críticos.

---

2. Alcance del análisis

- Revision de logs**:**
  - `/var/log/auth.log`
  - `/var/log/daemon.log`
  - `www-access.log`
- Identificación de:
  - Intentos de acceso
  - Accesos exitosos
  - Actividades posteriores del acceso
  - Indicadores de compromiso (IOCs)

---

3. Hallazgos Principales

3.1 Intentos de acceso no autorizados

Se identificaron múltiples eventos de autenticación fallida mediante SSH:

```
Apr 20 02:55:35 app-1 sshd[25341]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=root
Apr 20 02:55:39 app-1 sshd[25343]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=root
Apr 20 02:55:44 app-1 sshd[25345]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=root
Apr 20 02:55:50 app-1 sshd[25347]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=root
Apr 20 02:55:54 app-1 sshd[25349]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=root
Apr 20 02:55:58 app-1 sshd[25351]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=root
Apr 20 02:56:04 app-1 sshd[25363]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=root
Apr 20 02:56:08 app-1 sshd[25365]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:13 app-1 sshd[25367]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:18 app-1 sshd[25369]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:23 app-1 sshd[25371]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:27 app-1 sshd[25373]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:32 app-1 sshd[25375]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:37 app-1 sshd[25377]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:45 app-1 sshd[25379]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:50 app-1 sshd[25381]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:55 app-1 sshd[25383]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:56:59 app-1 sshd[25385]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=www-data
Apr 20 02:57:03 app-1 sshd[25387]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:57:09 app-1 sshd[25389]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:57:14 app-1 sshd[25391]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=nobody
Apr 20 02:57:22 app-1 sshd[25393]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=root
Apr 20 02:57:27 app-1 sshd[25395]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130  user=backup
Apr 20 02:57:31 app-1 sshd[25397]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
Apr 20 02:57:43 app-1 sshd[25399]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=125.235.4.130
```

```
Apr 24 14:49:19 app-1 sshd[31139]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 14:49:21 app-1 sshd[31141]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 14:49:23 app-1 sshd[31143]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 14:49:26 app-1 sshd[31145]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 14:49:28 app-1 sshd[31147]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 14:49:30 app-1 sshd[31149]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 14:49:33 app-1 sshd[31151]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 14:49:35 app-1 sshd[31153]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 14:49:38 app-1 sshd[31155]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 14:49:40 app-1 sshd[31157]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=8.12.45.242
Apr 24 15:25:58 app-1 sshd[31248]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=61.168.227.12  user=root
Apr 24 15:26:02 app-1 sshd[31258]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=61.168.227.12  user=root
Apr 24 15:26:06 app-1 sshd[31262]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=61.168.227.12  user=root
Apr 24 15:26:11 app-1 sshd[31264]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=61.168.227.12  user=root
Apr 24 15:26:15 app-1 sshd[31266]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=61.168.227.12  user=root
Apr 24 15:26:19 app-1 sshd[31268]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=61.168.227.12  user=root
Apr 24 15:26:23 app-1 sshd[31270]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=61.168.227.12  user=root
```

Características:

- **Intentos repetitivos de autenticación**
- **Uso del servicio SSH**
- **Multiples IPs externas**

3.2 Acceso exitoso al sistema

Se detectó el siguiente evento crítico:

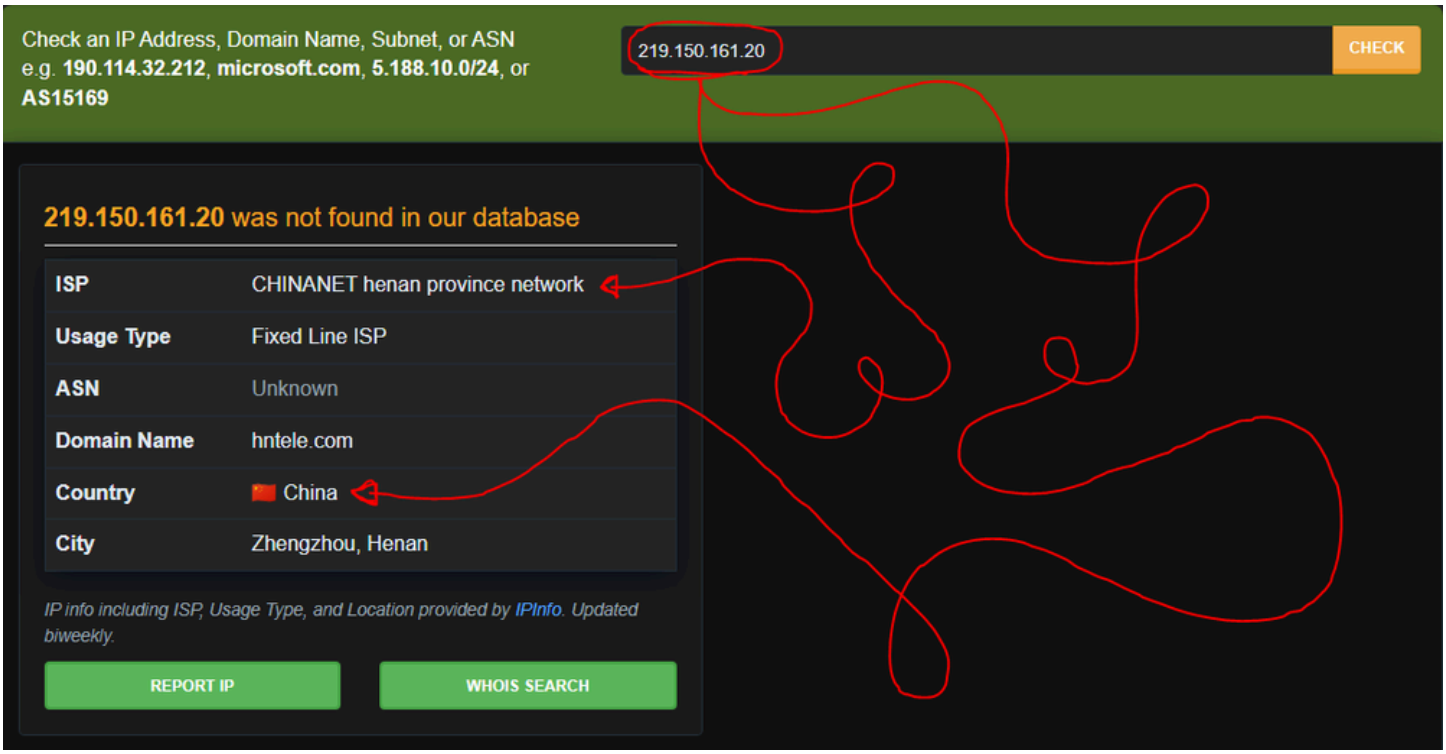
```
Apr 19 05:41:44 app-1 sshd[8810]: Accepted password for root from 219.150.161.20 port 51249 ssh2
Apr 19 05:42:27 app-1 sshd[9031]: Accepted password for root from 219.150.161.20 port 40877 ssh2
Apr 19 05:55:20 app-1 sshd[12996]: Accepted password for root from 219.150.161.20 port 55545 ssh2
Apr 19 05:56:05 app-1 sshd[13218]: Accepted password for root from 219.150.161.20 port 36585 ssh2
```

Interpretación:

- Autenticación exitosa vía SSH
- Uso de contraseña (no clave pública)
- Acceso con privilegios máximos (root)

En **AbuseIPDB**, se observa que la dirección **219.150.161.20** es una IP pública ubicada en China, asignada al proveedor:

- ISP (Proveedor): China Telecom
- ASN: 4134 (Chinanet)
- País: China
- Ciudad: información completa no disponible
- Zona horaria: Asia/Shanghai



Esto indica que la IP pertenece a un rango de direcciones públicas chinas usados por clientes finales o servicios de red de **China Telecom**.

3.3 Actividad posterior al acceso (Post-Compromise)

Creación de usuario: **wind3str0y**

```
Apr 25 10:41:44 app-1 useradd[9596]: new group: name=fido, GID=1004
Apr 25 10:41:44 app-1 useradd[9596]: new user: name=fido, UID=0, GID=1004, home=/home/fido, shell=/bin/sh
Apr 26 04:43:15 app-1 useradd[20115]: new user: name=wind3str0y, UID=1004, GID=1005, home=/home/wind3str0y, shell=/bin/bash
```

- Creación de cuenta local
- Acceso interactivo (**`/bin/bash`**)
- Persistencia en el sistema

Modificación de firewall (**IPtables**)

```
Apr 24 19:25:37 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -L
Apr 24 20:03:06 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p ssh -dport 2424 -j ACCEPT
Apr 24 20:03:44 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp -dport 53 -j ACCEPT
Apr 24 20:04:13 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p udp -dport 53 -j ACCEPT
Apr 24 20:06:22 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp --dport ssh -j ACCEPT
Apr 24 20:11:00 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp --dport 53 -j ACCEPT
Apr 24 20:11:08 app-1 sudo:     root : TTY=pts/2 ; PWD=/etc ; USER=root ; COMMAND=/sbin/iptables -A INPUT -p tcp --dport 113 -j ACCEPT
```

- Apertura de puertos
- Posible habilitación de comunicación externa
- Indicios de persistencia o evasión

Configuración insegura en **MySQL**

Se muestran mensajes de advertencia indicando que **mysql.user contiene 2 cuentas root sin contraseña**:

```
Mar 18 10:18:42 app-1 /etc/mysql/debian-start[7566]: WARNING: mysql.user contains 2 root accounts without password!
Mar 18 17:01:44 app-1 /etc/mysql/debian-start[14717]: WARNING: mysql.user contains 2 root accounts without password!
Mar 22 13:49:49 app-1 /etc/mysql/debian-start[5599]: WARNING: mysql.user contains 2 root accounts without password!
Mar 22 18:43:41 app-1 /etc/mysql/debian-start[4755]: WARNING: mysql.user contains 2 root accounts without password!
Mar 22 18:45:25 app-1 /etc/mysql/debian-start[4749]: WARNING: mysql.user contains 2 root accounts without password!
Mar 25 11:56:53 app-1 /etc/mysql/debian-start[4848]: WARNING: mysql.user contains 2 root accounts without password!
Apr 14 14:44:34 app-1 /etc/mysql/debian-start[5369]: WARNING: mysql.user contains 2 root accounts without password!
Apr 14 14:44:36 app-1 /etc/mysql/debian-start[5624]: WARNING: mysqlcheck has found corrupt tables
Apr 18 18:04:00 app-1 /etc/mysql/debian-start[4647]: WARNING: mysql.user contains 2 root accounts without password!
Apr 24 20:21:24 app-1 /etc/mysql/debian-start[5427]: WARNING: mysql.user contains 2 root accounts without password!
Apr 28 07:34:26 app-1 /etc/mysql/debian-start[4782]: WARNING: mysql.user contains 2 root accounts without password!
Apr 28 07:34:27 app-1 /etc/mysql/debian-start[5032]: WARNING: mysqlcheck has found corrupt tables
May  2 23:05:54 app-1 /etc/mysql/debian-start[4774]: WARNING: mysql.user contains 2 root accounts without password!
```

Esto indica un riesgo típico de acceso no autorizado.

3.4 Actividad sospechosa en servidor web

Durante el análisis del archivo de registros de acceso web (www-access.log), se identificaron múltiples valores de User-Agent asociados a las solicitudes HTTP realizadas al servidor.

Se identificaron los siguientes User-Agent relevantes:

```
checho@Windows-localhost:~/Hammered/apache2$ cat www-access.log | cut -d ' ' -f 12 | sort | uniq
"-"
"Apple-PubSub/65.12.1"
"Mozilla/4.0
"Mozilla/5.0
"WordPress/2.9.2;
"pxyscand/2.1"
```

Herramienta de escaneo detectada `pxyscand/2.1`

Se identificó la presencia del **User-Agent**:

```
checho@Windows-localhost:~/Hammered/apache2$ cat www-access.log | cut -d ' ' -f 12 | sort | uniq
"-"
"Apple-PubSub/65.12.1"
"Mozilla/4.0
"Mozilla/5.0
"WordPress/2.9.2;
"pxyscand/2.1"
```

Este valor es altamente relevante desde el punto de vista de seguridad.

Características:

- Corresponde a una herramienta automatizada de escaneo
- Utilizada para: Identificación de proxies abiertos, enumeración de servicios web y reconocimiento de infraestructura.

El sistema fue objetivo de múltiples vectores de reconocimiento, tanto a nivel de servicios web como de acceso remoto (SSH).

---

4. Impacto

El incidente analizado evidencia un compromiso significativo del sistema, derivado de un acceso exitoso mediante autenticación SSH utilizando credenciales válidas del usuario con mayores privilegios. A partir de los hallazgos identificados en los registros, es posible evaluar el impacto en los tres pilares del modelo **CIA (Confidencialidad, Integridad y Disponibilidad)**.

4.1 Impacto en la Confidencialidad

El acceso exitoso al sistema utilizando la cuenta **root** implica que el actor tuvo la capacidad de:

- Acceder a **todos los archivos del sistema**, incluyendo:
  - Configuraciones críticas
  - Bases de datos
  - Credenciales almacenadas
- Leer información sensible de usuarios
- Inspeccionar claves privadas, tokens o configuraciones de servicios

Existe un alto riesgo de exposición total de la información contenida en el sistema.

4.2 Impacto en la Integridad

Se identificaron múltiples acciones que evidencian modificaciones en el sistema:

- Creación de una nueva cuenta local (**`wind3str0y`**)
- Modificación de reglas de firewall mediante **`iptables`**
- Configuraciones inseguras en servicios (**cuentas root sin contraseña en MySQL**)

Estas acciones demuestran que el sistema fue alterado, permitiendo:

- Cambios en configuraciones de seguridad
- Instalación o ejecución de herramientas no autorizadas
- Alteración de logs o eliminación de evidencias

La integridad del sistema se encuentra comprometida, ya que no es posible garantizar que los datos o configuraciones permanezcan confiables.

4.3 Impacto en la Disponibilidad

Aunque no se observaron evidencias directas de interrupción del servicio, las acciones detectadas podrían derivar en:

- Uso del sistema para actividades externas (pivoting, escaneo, botnet)
- Consumo excesivo de recursos
- Posibles bloqueos o inestabilidad del sistema

Además, la manipulación del firewall podría afectar:

- Accesos legítimos
- Disponibilidad de servicios críticos

Existe un riesgo potencial sobre la disponibilidad, incluso si no se materializó completamente durante el periodo analizado.

---

5. Mapeo al Marco MITRE ATT&CK

Táctica	Técnica	ID	Descripción	Evidencia
Reconnaissance	Active Scanning	T1595.001	Escaneo activo de servicios para identificar objetivos	`User-Agent pxyscand/2.1` en `www-access.log`
Initial Access	Valid Accounts	T1078	Uso de credenciales válidas para autenticarse	`Accepted password for root` en `auth.log`
Credential Access	Brute Force	T1110	Intentos repetidos de autenticación	`authentication failure` múltiples IPs
Execution	Command and Scripting Interpreter	T1059	Ejecución de comandos en el sistema	Uso de `iptables`, `useradd`
Persistence	Create Account	T1136	Creación de cuentas para mantener acceso	Usuario `wind3str0y` creado
Privilege Escalation	Valid Accounts	T1078	Uso de cuenta con privilegios elevados	Acceso directo como `root`
Defense Evasion	Modify System Configuration	T1112	modificación de configuraciones del sistema	Reglas del firewall `iptables` añadidas
Discovery	System Information Discovery	T1082	Obtención de información del sistema	Enumeración implícita tras acceso

5. Conclusión

En conjunto, los hallazgos permiten establecer que el incidente no se limita a un acceso puntual, sino que corresponde a un escenario completo de compromiso, donde se abarcan fases de reconocimiento, acceso inicial y actividades posteriores dentro del sistema. La correlación de eventos entre distintos logs confirma una secuencia coherente de acciones que afectan la seguridad global del entorno.

Desde una perspectiva de seguridad, el incidente refleja debilidades críticas en la configuración del sistema, especialmente en lo relacionado con la gestión de accesos remotos y el uso de credenciales privilegiadas. La falta de controles robustos permitió que un acceso externo derivara en control total del sistema.

Finalmente, se concluye que el servidor analizado se encuentra en un estado comprometido, donde no es posible garantizar la confiabilidad de la información ni de las configuraciones actuales. Por lo tanto, se recomienda tratar el sistema como no confiable, aplicar medidas de contención inmediatas y considerar procesos de recuperación que incluyan la reinstalación del sistema y el fortalecimiento de controles de seguridad para prevenir incidentes similares en el futuro.